

# Security Incident Report

**Incident ID:** INC-2026-0809-001  
**Classification:** Brute Force Attack — Successful Compromise  
**Severity:** High  
**Status:** Confirmed / Closed (simulated investigation)  
**Analyst:** Abdul Jalal Raoufi  
**Date of Investigation:** August 9, 2026

## Executive Summary

On August 9, 2026, a brute force attack was identified against the admin account on authserver. The attack originated from a single external IP address (185.220.101.47) and consisted of 47 failed login attempts over approximately 3 minutes, followed by a successful login and an established root-level session. This report documents the investigation timeline, evidence, impact, and recommended remediation steps.

## Environment

- Log source: auth.log (simulated SSH authentication log)
- Host: authserver
- SIEM tool used for investigation: Splunk Enterprise (local instance)
- Total events analyzed: 72 (background traffic + attack)

## Timeline of Events

| Time                | Event                                                        |
|---------------------|--------------------------------------------------------------|
| 04:07:03            | First failed login attempt against admin from 185.220.101.47 |
| 04:07:03 – 04:10:10 | 47 total failed login attempts, roughly 1 every 4 seconds    |
| 04:10:10            | Final failed login attempt                                   |
| 04:10:14            | Successful login — credentials accepted for admin            |
| 04:10:15            | Session opened for admin (uid=0 — root-level access)         |

**Total attack duration:** ~3 minutes 11 seconds

Attack pattern: Consistent, rapid-fire attempts (~1 every 4 seconds) — indicative of automated tooling rather than manual entry.

## Investigation Methodology

1. Ingested auth.log into Splunk as a custom source type.
2. Ran an initial search across all events to establish a baseline of normal authentication activity and visually identify anomalies via the event timeline histogram.
3. Filtered specifically for failed login attempts, returning 47 events.
4. Extracted the source IP from each event and grouped by IP to confirm the attack originated from a single source rather than a distributed set of IPs.
5. Calculated first and last attempt timestamps to establish the attack window.

6. Searched for the corresponding successful login and session-open event to confirm the moment of compromise and privilege level obtained.
7. Built a time-bucketed visualization to produce a chart of attempt volume over time.

## Evidence

Splunk search confirming single-source attack:

```
source="auth.log" "Failed password" | rex "from (?<src_ip>\d+\.\d+\.\d+\.\d+)" | stats count by src_ip
```

Result: 185.220.101.47, count = 47

The screenshot shows the Splunk Enterprise interface. The search bar contains the query: `source="auth.log" "Failed password" | rex "from (?<src_ip>\d+\.\d+\.\d+\.\d+)" | stats count by src_ip`. The search results show 47 events. The table has two columns: `src_ip` and `count`. The results are as follows:

| src_ip         | count |
|----------------|-------|
| 185.220.101.47 | 47    |

Splunk search confirming attack window:

```
source="auth.log" "Failed password" | rex "from (?<src_ip>\d+\.\d+\.\d+\.\d+)" | stats earliest(_time) as first_attempt, latest(_time) as last_attempt, count by src_ip | eval first_attempt=strftime(first_attempt, "%Y-%m-%d %H:%M:%S") | eval last_attempt=strftime(last_attempt, "%Y-%m-%d %H:%M:%S")
```

Result: first\_attempt = 2026-08-09 04:07:03, last\_attempt = 2026-08-09 04:10:10

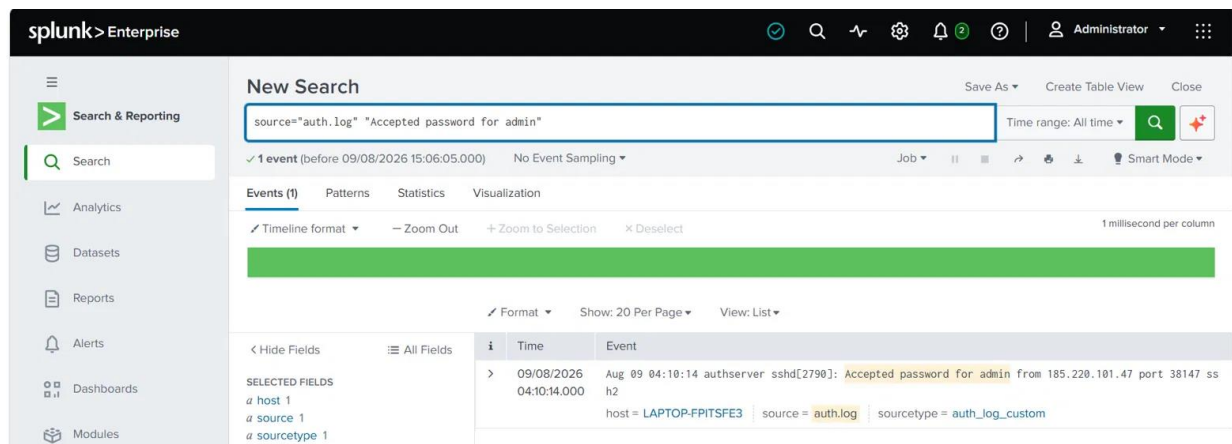
The screenshot shows the Splunk Enterprise interface. The search bar contains the query: `source="auth.log" "Failed password" | rex "from (?<src_ip>\d+\.\d+\.\d+\.\d+)" | stats earliest(_time) as first_attempt, latest(_time) as last_attempt, count by src_ip | eval first_attempt=strftime(first_attempt, "%Y-%m-%d %H:%M:%S") | eval last_attempt=strftime(last_attempt, "%Y-%m-%d %H:%M:%S")`. The search results show 47 events. The table has four columns: `src_ip`, `first_attempt`, `last_attempt`, and `count`. The results are as follows:

| src_ip         | first_attempt       | last_attempt        | count |
|----------------|---------------------|---------------------|-------|
| 185.220.101.47 | 2026-08-09 04:07:03 | 2026-08-09 04:10:10 | 47    |

Splunk search confirming compromise:

```
source="auth.log" "Accepted password for admin"
```

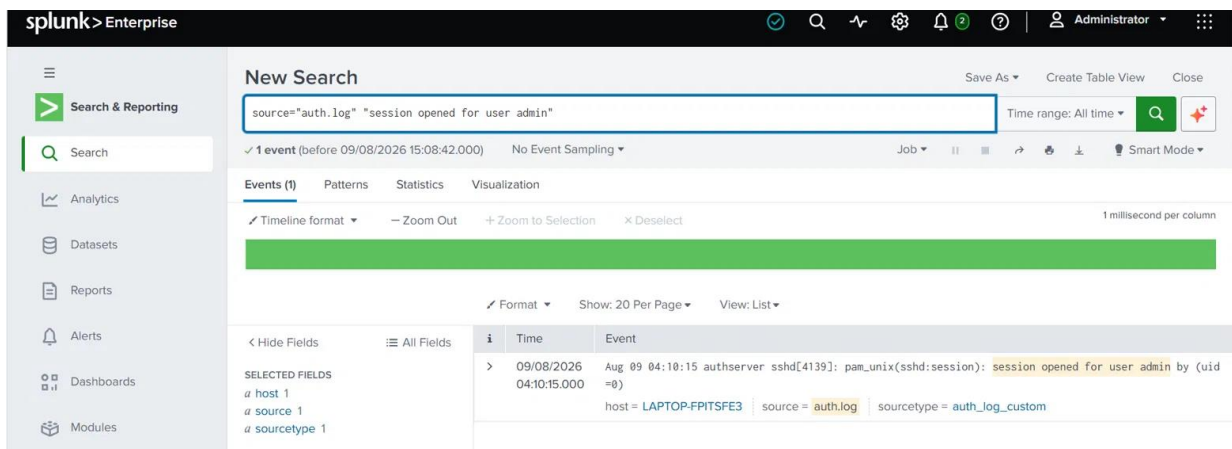
Result: single event at 04:10:14 from 185.220.101.47



Splunk search confirming root-level session:

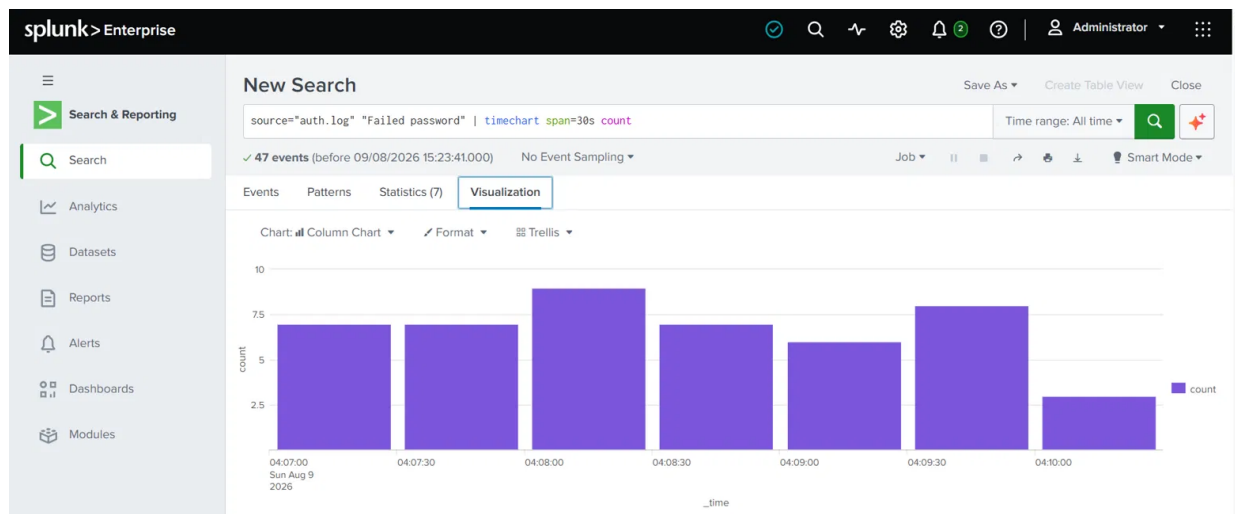
`source="auth.log" "session opened for user admin"`

Result: session opened at 04:10:15, uid=0



Visualization:

Column chart (30-second buckets) showing failed login attempts clustered between 04:07:00 and 04:10:00, with 5–8 attempts per bucket.



## Impact Assessment

The admin account was fully compromised, with the attacker obtaining an active root-level session (uid=0). This represents a critical impact scenario: with root access, an attacker could read, modify, or delete any data on the host; install persistence mechanisms (backdoors, new accounts, scheduled tasks); pivot to other systems on the network; or exfiltrate sensitive data. Because the attack succeeded in under 3.5 minutes with no apparent rate-limiting or lockout, this account was effectively undefended against a basic automated brute-force attempt.

## Detection Gaps Identified

- No account lockout or rate-limiting was in place — the attacker was able to make 47 consecutive attempts in under 4 minutes without being blocked or throttled.
- No indication of real-time alerting on this activity — a 47-attempt failure burst from a single IP against a privileged account should trigger an immediate high-priority alert in a properly monitored environment, but this investigation relied on manual, after-the-fact log review rather than a live alert.

## Recommendations

8. Implement account lockout after a low threshold of failed attempts (e.g. 5), with a cooldown period before retry is allowed.
9. Implement rate-limiting on the authentication endpoint, independent of account lockout, to slow automated attack tools regardless of which account they target.
10. Enforce strong password policy on all accounts, especially privileged ones — the compromised password should be evaluated against a breached-password list and rejected if it appears there.
11. Configure real-time alerting in the SIEM for authentication failure bursts so that this type of attack is caught while in progress, not after the fact.
12. Enable multi-factor authentication (MFA) on privileged/admin accounts, so that a compromised password alone is insufficient for account takeover.
13. Review and rotate the compromised account's credentials immediately, and audit any actions taken during the attacker's session window for signs of further compromise.

## Conclusion

This investigation confirmed a successful, automated brute-force attack against a privileged account, enabled by the absence of basic authentication safeguards (rate-limiting, lockout, alerting). The attack was fully reconstructed after the fact using Splunk log analysis, but the underlying detection gap — no real-time alerting on authentication failure bursts — meant this activity would have gone unnoticed in a live environment until much later, if at all. Closing that detection gap is the single highest-priority recommendation from this investigation.